

Grafos de Conhecimento Centrados na Sessão HTTP para Detecção Explicável e Mitigação de Escopo Derivado de DDoS Distribuído de Camada de Aplicação

Natanael Oliveira, Arthur Kobielski, Marcos Luna, Luigi Carro, Jéferson Campos Nobre e Eder John Scheid
Instituto de Informática, Universidade Federal do Rio Grande do Sul (UFRGS), Porto Alegre, Brasil
{natanael.oliveira, arthur.kobielski, marcos.luna, carro, jcnobre, ejscheid}@inf.ufrgs.br

Resumo—Campanhas distribuídas de Slow HTTP DoS mantêm cada origem abaixo de qualquer limiar razoável por sessão, de modo que o sinal de ataque mora na estrutura *entre* sessões e não dentro de nenhuma delas. Os detectores descartam essa estrutura ao reduzir a sessão a um vetor numérico, e os detectores recentes baseados em grafos de conhecimento raciocinam em nível de nó de rede e param no relatório textual. Modelamos a sessão HTTP como entidade ontológica de primeira classe em OWL e substituímos a relação plana `relatedTo` por seis sub-propriedades tipadas, ponderadas pelo custo que o atacante teria para quebrar cada sinal; a proximidade de rede fica em último lugar porque *botnets* modernas se distribuem agressivamente entre ASNs e prefixos. Uma regra SPARQL/SWRL dispara sobre a massa ponderada dessas sub-relações, e sua derivação é o veredicto, exportado como cadeia de evidência em JSON-LD e STIX 2.1 cujo discriminador define o escopo da mitigação. Contra campanhas furtivas distribuídas, a detecção por sessão permanece no acaso em quatro famílias de modelo, mesmo com o conjunto completo de atributos de fluxo, enquanto o raciocínio entre sessões as detecta de forma consistente (ROC AUC 0,50 vs. 0,98; $d = 22,4$). Em *datasets* públicos, cujos ataques carregam assinatura de fluxo evidente, um *baseline* por sessão forte já basta, e reportamos essa delimitação explicitamente. Mostramos ainda que a maneira óbvia de derivar o escopo da mitigação é nociva: a propriedade que a maioria do *cluster* compartilha é um *fingerprint* legítimo assim que a *botnet* abrange vários *stacks* TLS, bloqueando 0% do ataque e 39% dos usuários. Escolher o discriminador por enriquecimento sobre um perfil de tráfego normal bloqueia 85–90% a 0,00% de colateral. E, avaliado como detector, esse caminho simbólico dispensa treino e limiar, recuperando de duas a cinco vezes mais de uma campanha fragmentada do que o modelo aprendido consegue no mesmo ponto de operação de falso positivo zero.

Index Terms—gestão de segurança, grafo de conhecimento, DDoS de camada de aplicação, modelos semânticos, raciocínio automatizado, explicabilidade, política de mitigação

I. INTRODUÇÃO

O DDoS de camada de aplicação mudou de natureza, não apenas de escala. Em agosto de 2023, o HTTP/2 Rapid Reset (CVE-2023-44487) levou os picos mitigados a 398 milhões de requisições por segundo, a partir de uma *botnet* de cerca de vinte mil máquinas [1], [2], e a Cloudflare bloqueou mais de 6 500 ataques hiper-volumétricos só no segundo trimestre de 2025, com o DDoS sobre HTTP crescendo 129% ano a

ano [3]. As defesas volumétricas respondem pela ponta ruidosa desse espectro. A ponta silenciosa é mais difícil. A família de ataques *distribuídos de Slow HTTP DoS* abrange o Slowloris e seus descendentes, mais variantes baseadas em taxa que ainda sustentam conexões abertas, como HULK e GoldenEye [4]. Esses ataques exaurem um servidor a partir de muitas origens coordenadas, cada uma contribuindo tão pouco que nenhum limiar por origem é ultrapassado. Ataques modernos sobre HTTP/2 compartilham essa propriedade de exaustão multi-origem, mas operam por mecanismos distintos, notadamente cancelamento de *stream* e abuso de cabeçalhos de continuação. Esses exigem sub-relações fora do escopo que avaliamos aqui, e os tratamos como alvo de extensão imediata (Seção VII), não como afirmação deste artigo.

Vista isoladamente, cada requisição é indistinguível de uma legítima. O sinal mora na estrutura *entre* sessões: duração da conexão, entropia de rotas, consistência do *fingerprint* do cliente e a convergência de muitas origens num mesmo *endpoint* sob uma mesma assinatura de cliente [5].

Isto é tanto um problema de gestão de redes e serviços quanto de detecção. Um operador não precisa de um rótulo; precisa saber *quais* clientes bloquear, com base em *qual* evidência, e com um filtro estreito o bastante para não desconectar os usuários legítimos do próprio serviço sob ataque.

A literatura reconhece a primeira metade e ignora largamente a segunda. A meta-análise de Odusami et al. [6], sobre setenta e cinco estudos, mostra que 47% dos métodos de DDoS de camada de aplicação derivam atributos de sessões, como taxa de requisições por usuário, duração média e operações por identidade. Em todos eles a sessão é achatada num vetor numérico antes de chegar ao classificador. O detector vê estatísticas, não sessões, e por isso não consegue raciocinar sobre identidades reaproveitadas, sobre *fingerprints* convergindo num *endpoint*, ou sobre padrões que só existem entre duas sessões individualmente normais.

Trabalhos contemporâneos atacam a opacidade desses detectores com grafos. O KLAGÉ, de Belcastro et al. [7], constrói grafos de conhecimento a partir de *logs* de rede, classifica nós com Graph-BERT e produz relatórios em linguagem natural via LIME e modelos de linguagem grandes,

atingindo $F_1 = 84,1\%$ em *benchmarks* IoT que incluem DDoS Slowloris. É evidência sólida de que grafos de conhecimento são substrato viável de detecção em tempo de execução. Três lacunas, contudo, permanecem. Sua unidade de raciocínio é o *nó de rede* (porta, IP, fluxo), e não a sessão de aplicação. A coordenação é capturada implicitamente em *embeddings* aprendidos, e não em relações simbólicas nomeadas. E o *pipeline* termina num relatório, sem uma política de mitigação cujo escopo derive do próprio grafo. Essas três lacunas delimitam o espaço que este artigo ocupa.

Contribuições. São quatro:

- 1) **A sessão HTTP como entidade ontológica de primeira classe, com uma família *relatedTo* ponderada.** Uma ontologia OWL modela *ApplicationSession* com relações tipadas para identidade do cliente, *endpoint* alvo, comportamento exibido e mitigação aplicável, e substitui a relação plana *relatedTo* por uma família de *seis sub-propriedades tipadas e ponderadas*. Os pesos codificam o custo que o atacante teria para quebrar cada sinal. A proximidade de rede, trivialmente quebrada por *botnets* modernas, entra portanto como evidência auxiliar e nunca como pré-requisito.
- 2) **Raciocínio simbólico sobre a soma ponderada das sub-relações.** Um *pipeline* em tempo de execução eleva eventos HTTP a instâncias da ontologia, instanciando cada sub-propriedade independentemente a partir de sua própria evidência. Uma regra SPARQL/SWRL dispara sobre a massa ponderada de coordenação $\Omega(S)$ de um *cluster* candidato. O veredicto é a derivação que satisfaz a regra, não a saída de um classificador interpretada a posteriori.
- 3) **Uma cadeia de evidência acoplada à derivação automática de escopo de mitigação.** Cada veredicto carrega uma cadeia em JSON-LD e STIX 2.1 que lista as sub-relações ativadas, seus pesos e os valores que satisfizeram a regra, e o escopo da mitigação é derivado do mesmo grafo. Mostramos que a maneira natural de derivá-lo, pela propriedade que a maioria do *cluster* compartilha, é ativamente nociva em condições realistas, e a substituímos por um critério baseado em enriquecimento sobre um perfil de tráfego normal.
- 4) **Uma avaliação parametrizada pelo grau de distribuição, com métrica de dano colateral.** Contra um *baseline* por sessão deliberadamente *forte*, a ablação isola o ganho do raciocínio entre sessões e o ganho específico dos sinais de peso alto sobre a proximidade de rede. Reportamos também a fração de tráfego legítimo atingida pela mitigação resultante, métrica auto-reportada por produtos comerciais de *bot management* mas, até onde sabemos, não usada sistematicamente na literatura acadêmica de Camada 7. A implementação de referência é código aberto.

A Seção II posiciona o trabalho, a Seção III apresenta o arcabouço, as Seções IV e V a metodologia e os resultados, e

a Seção VI as limitações que delimitam a afirmação.

II. TRABALHOS RELACIONADOS

A. Grafos de Conhecimento em Segurança e Gestão

A primeira onda de grafos de conhecimento em segurança foi *estática*: entidades extraídas de CVEs, relatórios e *blogs*, normalizadas e ligadas numa base consultável [8], [9]. O levantamento de Liu et al. [10] enuncia a lacuna resultante sem rodeios: “ainda é pouco claro como implementar o grafo de conhecimento para enfrentar dificuldades industriais reais em situações de ataque e defesa cibernética”. Grafos construídos a partir de texto de inteligência de ameaças não capturam estrutura de tráfego em tempo de execução.

Trabalhos mais recentes populam grafos a partir do próprio tráfego. O KLAGÉ [7] é o exemplar mais próximo e aquele contra o qual comparamos. Representações em grafo também vêm ganhando espaço em tarefas de gestão adjacentes à nossa: Sadlek et al. [11] identificam dependências entre dispositivos por predição de arestas sobre grafos de rede, e Wang e Stadler [12] aprendem sequências de ações de ataque a partir de medições em *testbed*. Ambos operam sobre entidades em nível de rede. Diferimos deles em três eixos. Nossa unidade de raciocínio é a sessão de aplicação; nosso formalismo são relações simbólicas nomeadas, e não *embeddings* aprendidos; e nossa saída inclui o escopo da mitigação.

B. Detecção de DDoS de Camada 7 sobre HTTP

A detecção se organiza historicamente em duas famílias, sobre um corpo de levantamentos que consolidam o domínio [4], [13]. O perfilamento estatístico constrói linhas de base a partir de estatísticas agregadas de fluxo ou sessão: Fernandes et al. [14] com PCA sobre estatísticas de fluxo, e Bharathi e Sukanesh [15] com PCA sobre uma matriz comportamental por sessão, que é uma das primeiras formulações a colocar a sessão no centro, ainda que como vetor de atributos. O aprendizado supervisionado sobre atributos de sessão é a segunda família, com Kemp et al. [5] como representante mais recente; seus autores registram que o método não foi validado em tempo real e que a saída é binária, sem explicação ontológica. O denominador comum é que a sessão é tratada como agregado de atributos, nunca como entidade sobre a qual se possa raciocinar.

C. Modelagem de Sessão em Detecção de Anomalias

A meta-análise de Odusami et al. [6] fornece a evidência quantitativa mais clara sobre como a sessão é tratada: em 47% dos métodos catalogados, atributos derivados de sessão alimentam o classificador, mas em nenhum dos setenta e cinco estudos a sessão é mantida como objeto com identidade, alvo, comportamento e relações tipadas. A redução é uniforme, e é ela que coloca fora do alcance do detector o raciocínio sobre identidades reaproveitadas, sobre *fingerprints* convergindo num *endpoint*, ou sobre padrões visíveis apenas entre sessões.

Plataformas industriais de *bot management* de fato exploram estrutura entre sessões, agrupando sessões aparentemente

independentes por similaridade de *stack* TLS através de *fingerprints* da família JA4 [16]. São, contudo, proprietárias, sem ontologia pública, sem *benchmark* acadêmico reproduzível e sem métrica formalizada de dano colateral. Formalizar essa prática de modo auditável, e derivar o escopo de mitigação de uma regra ontológica explícita, é o que permanece em aberto.

III. GRAFO DE CONHECIMENTO CENTRADO NA SESSÃO

A Fig. 1 resume o arcabouço. Quatro estágios operam sobre o tráfego ao vivo: eventos HTTP são ingeridos; elevados a instâncias da ontologia, com sessões como nós persistentes do grafo; avaliados por regras semânticas; e convertidos num veredicto que carrega sua cadeia de evidência e o escopo de mitigação derivado.

A. Ontologia

A classe central é `ApplicationSession`, ligada por `hasIdentity` a uma `Identity` composta (`cookie`, `token`, `JWT`, `username`, `fingerprint` TLS), por `targets` a um `Endpoint` (`AuthEndpoint`, `APIEndpoint`, `StaticAsset`), por `exhibitsBehavior` a um perfil comportamental, e por `mitigatedBy` a uma política (`RateLimit`, `Challenge`, `Block`) que carrega um atributo `scope`. A classe abstrata `ApplicationLayerAttack` se especializa em `SlowHTTPDoSFamily`, por sua vez dividida em `ConnectionExhaustionAttack` (`Slowloris`, `slow body`, `slow read`) e `CoordinatedHTTPFlood` (`HULK`, `GoldenEye`). A ontologia está alinhada a STIX 2.1 [17] e MITRE ATT&CK, e declara também `CredentialStuffing` e `CoordinatedAPIAbuse`, que reaproveitam a mesma maquinaria mas estão fora do escopo experimental deste artigo.

B. Modelo de Ameaça

O defensor opera a aplicação atacada e observa, por requisição, o `ClientHello` TLS (e portanto um *fingerprint* JA4), endereço de origem e prefixo/ASN, *endpoint* alvo, instante de chegada, e o material de identidade que a aplicação expuser. Ele não observa o canal de controle da *botnet* e não tem verdade de campo sobre quais origens são coordenadas; pode, no entanto, perfilar o próprio tráfego fora de ataque. O atacante controla K origens, escolhe onde colocá-las na rede, e pode moldar cada sessão para ser estatisticamente indistinguível de uma legítima, que é a hipótese de furtividade da nossa avaliação. Ele pode ainda quebrar sinais individuais de coordenação: forjar o JA4 com bibliotecas que imitam navegadores, introduzir *jitter* na temporização, rotacionar identidades, randomizar *payloads*. Cada um desses movimentos tem custo operacional, e a ponderação da Seção III-C codifica esse custo; as Seções V-D e VI reportam o que acontece quando o sinal mais forte é retirado.

C. A Família *relatedTo* Ponderada

A relação entre sessões não é única, mas uma família estruturada, declarada via `rdfs:subPropertyOf` sob uma *relatedTo* transitiva e anotada com um

coordinationWeight $w_i \in [0,1]$, listada na Fig. 1. Cada uma é instanciada independentemente a partir de sua própria evidência observada, de modo que duas sessões podem estar ligadas por uma, várias ou todas as seis.

A ordenação é um argumento de custo de evasão. Trocar o *stack* TLS obriga o atacante a reescrever a infraestrutura, e é por isso que o JA4 sobreviveu à randomização de extensões que o Chrome introduziu em 2023, ao contrário do JA3 clássico [16]. O reaproveitamento de identidade é igualmente caro de quebrar, porque pulverizar credenciais ataca a economia da própria campanha. A coerência temporal emerge da operação da *botnet*, e não do *stack* cliente, e *jitter* aleatório pode quebrá-la parcialmente. Os sinais de *payload* e de *endpoint* são medianos: randomizá-los é barato, mas fazê-lo custa coerência de campanha. A proximidade de rede é o elo mais fraco por construção: derivados do Mirai, frotas de nuvem e redes de *proxies* residenciais se espalham entre ASNs e prefixos, e o CGN de operadora torna um /24 compartilhado um discriminador ruim. É essa ordenação de pesos, e não os valores absolutos, o que a calibração do Apêndice B corrobora.

D. Construção do Grafo em Tempo de Execução

Sessões e relações vivem dentro de uma janela operacional deslizante ($W = 5$ min por padrão) e são purgadas incrementalmente, seguindo uma disciplina de processamento de fluxos RDF. Adotamos o perfil OWL 2 RL [18], que admite materialização por encadeamento progressivo com comportamento quase-linear em consultas SPARQL indexadas, sobre Apache Jena Fuseki com armazenamento TDB2; *reasoners* OWL 2 DL completos não escalam para grafos desse tamanho. A Fig. 2 dispõe as duas camadas e as taxas em que operam; o Algoritmo 1 esboça a construção; o procedimento de decisão par a par de cada sub-relação *relatedBy* está no Apêndice A. Admitir uma sessão nova numa janela com $|S_W|$ sessões ativas custa $O(|S_W| \cdot c)$, com c amortizado $O(1)$ para todas as sub-relações exceto a temporal, dominada pelo FastDTW sob banda de Sakoe–Chiba. A Seção V-E mede tanto esse caminho de admissão quanto a camada simbólica em função da ocupação da janela.

E. Regra de Detecção

Seja V_{sess} o conjunto de sessões ativas em W . Para um subconjunto $S \subseteq V_{\text{sess}}$ e um *endpoint* candidato e , defina a massa de coordenação

$$\Omega(S) = \sum_{i \in \mathcal{R}_{\text{rel}}} w_i |E_i(S)|, \quad (1)$$

com $E_i(S) = \{\{s_a, s_b\} \subseteq S : (s_a, \text{relatedBy}_i, s_b) \in E\}$ o conjunto de pares de sessões ligados pela sub-relação i . As sub-relações são simétricas, então cada par não-ordenado conta uma vez. A regra `CoordinatedHTTPFlood` é satisfeita quando existe S com (i) $|S| \geq k_{\text{min}}$; (ii) $\forall s \in S : (s, \text{targets}, e) \in E$; (iii) $\Omega(S) \geq \tau_{\text{cluster}}$; (iv) taxa agregada em e acima de τ_{rate} ; e (v) um perfil `BotBehavior` coerente.

A condição (iii) é a contribuição. $\Omega(S)$ pode ultrapassar o limiar com `relatedByNetworkProximity` em zero, que é o

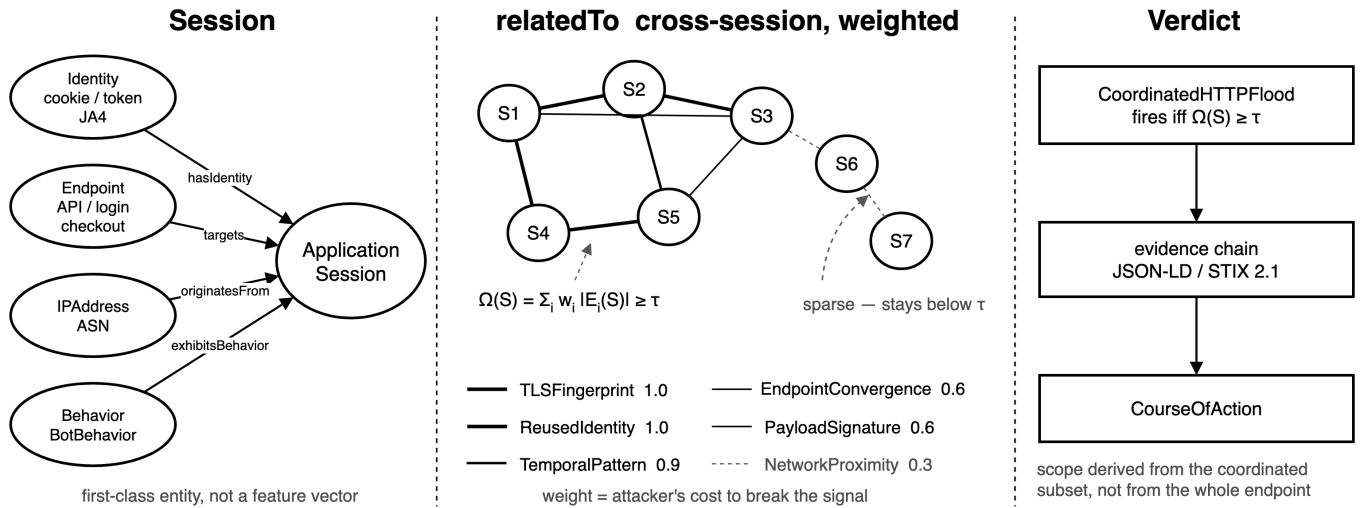


Fig. 1. Ontologia centrada na sessão. *ApplicationSession* é entidade de primeira classe, com relações primárias tipadas para identidade, origem, *endpoint* e comportamento; a família *relatedTo* ponderada liga as sessões entre si; e a regra de detecção acopla o veredicto simbólico a um curso de ação cujo escopo é derivado do subconjunto coordenado.

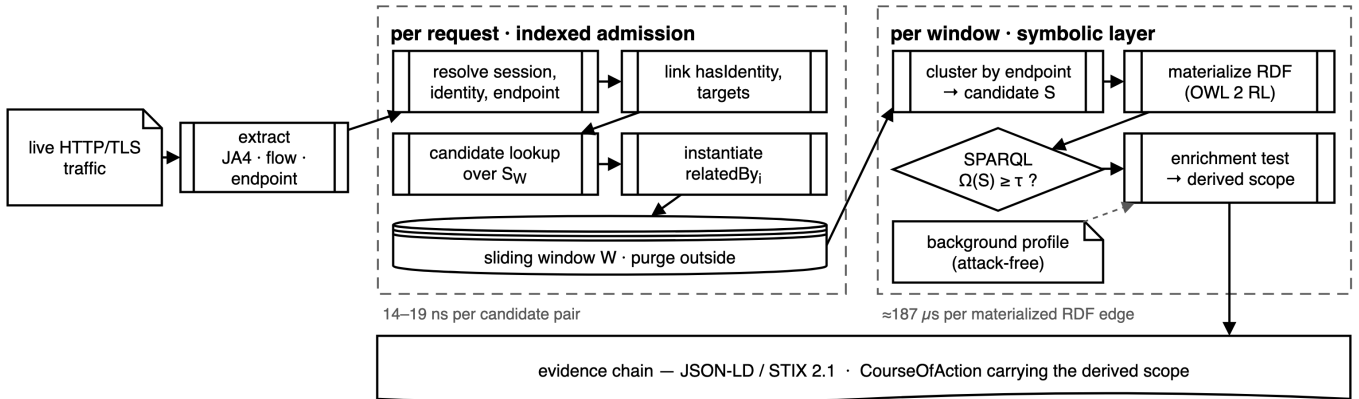


Fig. 2. O *pipeline* de execução, e a divisão que torna seu custo suportável. As duas camadas operam em taxas diferentes: a admissão é por requisição, sobre índices invertidos, enquanto a materialização RDF e a agregação de Ω acontecem uma vez por janela, quatro ordens de grandeza adiante por unidade de trabalho. O teste de enriquecimento lê um perfil de fundo construído fora de episódios de ataque, de modo que nenhum rótulo entra no caminho de decisão em momento algum.

caso da *botnet* distribuída, desde que alguma combinação de sinais de peso alto seja observada. Inversamente, um conjunto sustentado *apenas* por proximidade de rede, como usuários móveis legítimos atrás de um /24 de CGN, precisa de mais de três vezes mais pares ligados para atingir o mesmo Ω que um conjunto ligado por TLS, e τ_{cluster} é calibrado sobre *clusters* legítimos, de modo que a agregação usual de CGN fica abaixo dele. Isso é proteção explícita contra um modo de falso positivo bem conhecido.

F. Formulação Simbólica

O raciocínio é simbólico em dois estágios, e a divisão é deliberada. A instanciação par a par da família *relatedBy* é lógica de Horn pura e é expressa como regras SWRL; a agregação não é, porque SWRL não soma, então $\Omega(S)$ é computada por uma consulta SPARQL cujos pesos são

lidos das anotações *coordinationWeight* da ontologia, e não codificados no programa. A Listagem 1, no Apêndice A, mostra uma regra de cada tipo.

G. Cadeia de Evidência e Escopo de Mitigação Derivado

Quando a regra dispara, o motor emite a regra satisfeita, as instâncias ontológicas envolvidas, a decomposição de $\Omega(S)$ por sub-relação, e o escopo de mitigação derivado. Exportamos isso em JSON-LD sobre o vocabulário da ontologia e em STIX 2.1, um *indicator* mais um *course-of-action* ligados por *mitigates*, para ingestão em SIEM e SOAR.

Como o escopo é escolhido decide se o veredicto é útil ou nocivo, e a escolha óbvia é a errada. Tomar a propriedade compartilhada pela *maioria* do *cluster*, seu *fingerprint* modal, seleciona o que quer que seja comum. Num serviço sob ataque, o que é comum é a população legítima. Contra uma *botnet*

Algorithm 1 Construção do grafo em tempo de execução**Require:** fluxo de requisições $\mathcal{R}$, ontologia $\mathcal{O}$, janela W **Ensure:** grafo de conhecimento KG persistente em W

```

1:  $KG \leftarrow \emptyset$ 
2: for cada requisição  $r \in \mathcal{R}$  do
3:    $s, i, e \leftarrow \text{RESOLVEMESSAO/IDENTIDADE/ENDPOINT}(r)$ 

4:    $KG.\text{add}(s, i, e); KG.\text{link}(s, \text{hasIdentity}, i)$ 
5:    $KG.\text{link}(s, \text{targets}, e)$ 
6:   for cada  $s' \in S_W$  ativa,  $s' \neq s$  do
7:     for cada sub-relação  $i \in \mathcal{R}_{\text{rel}}$  do
8:       if  $\text{VALE}_i(s, s')$  then
9:          $KG.\text{link}(s, \text{relatedBy}_i, s')$ 
10:      end if
11:    end for
12:  end for
13:   $KG.\text{purgarFora}(W)$ 
14: end for
15: return  $KG$ 

```

espalhada por vários *stacks* TLS, cada grupo de atacantes é menor que a cabeça da distribuição benigna de *fingerprints*, de modo que o valor modal é um *fingerprint* legítimo e o filtro resultante bloqueia usuários e nenhum atacante. Medimos isso na Seção V-D.

Selecionamos portanto o discriminador por **enriquecimento**, e não por frequência. Seja $c(f)$ a prevalência do *fingerprint* f dentro do *cluster* que disparou e $b(f)$ sua prevalência num perfil de fundo de tráfego normal, mantido pelo operador fora de episódios de ataque. O escopo admite todo f com $c(f)/b(f) \geq \rho$ e $c(f) \geq \sigma$, produzindo um conjunto de *fingerprints* em vez de um só, que é o que cobre uma *botnet* fragmentada. O piso de suporte σ precisa ficar abaixo da parcela do menor *stack* sobre o qual valha agir, isto é, abaixo de $1/M$ para uma *botnet* de M *stacks*. Baixá-lo não custa nada, porque quem mantém o tráfego legítimo de fora é o teste de enriquecimento, não o piso. Usamos $\rho = 3$ e $\sigma = 0,002$.

O fundo precisa vir de fora do episódio de ataque. Usar a própria janela não funciona: a campanha atravessa a janela inteira, então as prevalências no *cluster* e no fundo coincidem e todo candidato marca enriquecimento igual a um. Nenhum rótulo está envolvido, já que o perfil é o que um defensor observa em operação normal. Uma propriedade útil vem de graça: quando o adversário se esconde dentro de um *fingerprint* benigno popular, esse *fingerprint* por definição não está enriquecido, é recusado, e o arcabouço reporta que não há discriminador em vez de emitir um filtro que só machuca usuários.

IV. METODOLOGIA EXPERIMENTAL

A. Cenários e Conjuntos de Dados

A hipótese central é que o raciocínio simbólico ponderado entre sessões ganha sobre a detecção por sessão em proporção ao grau de distribuição K da campanha, de modo que a

avaliação é parametrizada por K e não por nome de ataque. O **Cenário A (concentrado, $K = 1$)** é o ataque clássico de alto volume e origem única: nenhuma aresta entre sessões é necessária para detectar, e espera-se que detectores volumétricos convencionais bastem; ele é degenerado para AUC por sessão e o discutimos à parte. O **Cenário B (moderadamente distribuído, $10 \leq K \leq 100$)** modela *botnets* pequenas ou operações limitadas por *proxies*, cada origem permanecendo dentro do próprio limite de taxa; aqui a proximidade de rede é apenas parcial e os sinais de peso alto precisam carregar a detecção. O **Cenário C (altamente distribuído, $K \geq 1000$)** dispersa a campanha por centenas de ASNs e prefixos, de modo que o sinal por sessão é desprezível e *relatedByNetworkProximity* fica praticamente vazia. Este é o regime em que a contribuição precisa se sustentar para ser operacionalmente significativa. Reportamos B ($K = 50$) e C ($K = 1000$).

Avaliação primária: tráfego sintético calibrado. Um gerador produz campanhas distribuídas de Slow HTTP DoS, a família da Seção III-A: sessões sustentadas de baixa taxa contra um *endpoint*, com verdade de campo de coordenação perfeitamente conhecida, parametrizadas por K , pela fração de origens que compartilham assinatura TLS e identidade, pela dispersão de IP/ASN e pela janela temporal.

Dois parâmetros desse gerador decidem se o cenário se parece com produção, e ambos estavam inicialmente ajustados na direção que favorece o arcabouço. Primeiro, a popularidade dos *fingerprints* benignos: sortear o JA4 legítimo *uniformemente* de um pool grande torna cada cliente legítimo quase único, ao passo que populações reais são concentradas, já que um navegador atualizado numa dada plataforma emite essencialmente um JA4 [16]. Medimos essa curva diretamente, sobre 6,33M de requisições TLS registradas num ponto de presença de *edge* em produção da Azion Technologies¹: 495 *fingerprints* JA4 distintos, o mais comum respondendo por 38,4% das requisições e os dez maiores por 93,8%. Duas ressalvas se aplicam: o *log* não carrega identificador de conexão, então a ponderação é por requisição e não por sessão, o que superpondera clientes pesados e, se algo, *superestima* a concentração; e a amostra é de um ponto de presença numa janela. O *testbed* CICIDS2017 [19] é ainda mais concentrado (52,7% de cabeça), de modo que a forma medida em laboratório é apenas indicativa.

Modelamos a popularidade benigna como uma curva de Zipf de expoente α e a varremos. A curva medida não é exatamente Zipf. Sua cabeça corresponde a $\alpha = 1,5$ (38,9% contra 38,4%) enquanto seu top dez corresponde a $\alpha = 2,0$ (94,2% contra 93,8%), de modo que a varredura a contém. Adotamos $\alpha = 1,5$ como canônico. Segundo, a composição da *botnet*: um único *fingerprint* compartilhado não é representativo, já que *botnets* reais abrangem classes de dispositivo como roteadores, câmeras IP, DVRs e impressoras [20], e portanto *stacks* TLS. Distribuímos a campanha por M *stacks*, uniformemente, que é

¹Medição de 22 de agosto de 2026, a partir de um *log* de acesso que a plataforma já coleta; o extrato contém apenas *fingerprints* de software cliente e suas frequências, sem endereço, *host*, URI, cabeçalho ou idioma.

a escolha conservadora para um dado M , e adotamos $M = 25$ como canônico. Nenhuma medição publicada fixa M , então o varremos em vez de escolher. Por fim, um modo *adversarial* faz a *botnet* adotar os *fingerprints* benignos mais comuns em vez dos próprios; isto é prática corrente, e não hipótese, já que as ferramentas de personificação de navegador distribuem modelos prontos de *ClientHello* para versões específicas de Chrome e Safari. As distribuições legítimas são calibradas contra as ~ 322 mil sessões benignas do CICIDS2017 e verificadas por testes de Kolmogorov–Smirnov: $D = 0,003$ para duração e $D = 0,002$ para número de requisições, ambos com $p > 0,8$, de modo que o ganho observado não pode vir de tráfego benigno artificialmente fácil. Um modo *furtivo* amostra as sessões atacantes das mesmas distribuições por sessão do tráfego benigno, de modo que a campanha só se revela pela estrutura entre sessões.

Dados reais. CICIDS2017 [19] (captura de quarta-feira: Slowloris, Slowhttptest, HULK, GoldenEye) e CIC-IoT2023 [21], este último o conjunto sobre o qual o KLAGÉ reporta $F_1 = 84,1\%$ para DDoS Slowloris, processados pelo mesmo *pipeline* de extração (PCAP $\rightarrow$ JA4 + fluxos $\rightarrow$ sessões $\rightarrow$ grafo). Ambos são capturas de *testbed* de laboratório, e não tráfego de produção, ressalva à qual voltamos na Seção VI.

B. Baselines, Configurações e Métricas

Cada combinação é executada $n = 30$ vezes com sementes distintas, produzindo intervalos de confiança por *bootstrap* e testes pareados. Todas as configurações consomem os mesmos atributos subjacentes de tráfego, de modo que a ablação separa *representação*, e não disponibilidade de dado. τ_{cluster} é fixado por cenário no percentil 99 de Ω sobre *clusters* legítimos.

O *baseline* por sessão é deliberadamente **forte**: uma *Random Forest* sobre todos os oito a nove atributos de fluxo disponíveis (contagem e duração de requisições, somas de *bytes* e pacotes nos dois sentidos, média e desvio-padrão do intervalo entre requisições). Para que o resultado negativo não dependa de uma única classe de hipótese, o repetimos com *histogram gradient boosting*, um *perceptron* de múltiplas camadas e regressão logística sobre os mesmos atributos. Reimplementamos também três *baselines* acadêmicos: perfilamento por PCA [14], *k-means* sobre uma matriz comportamental [15], e RF/SVM supervisionados sobre atributos de sessão [5]. Comparamos contra os números publicados do KLAGÉ no mesmo conjunto e no mesmo ataque. As quatro configurações de ablação são: **(a)** *baseline* de ML sem ontologia; **(b)** ontologia *sem nenhuma* sub-relação *relatedBy*, sessões como nós isolados; **(c)** ontologia com *apenas relatedByNetworkProximity*, emulando um detector ingênuo por ASN/prefixo; e **(d)** o arcabouço completo com as seis sub-relações ponderadas. Assim, (d)–(a) é a contribuição total, (d)–(b) o ganho de representar estrutura entre sessões, e (d)–(c) o ganho dos sinais de peso alto sobre a proximidade de rede.

Um ponto delimita o que esses números mostram, e é melhor declará-lo do que deixá-lo ser descoberto. A configuração (d) consome a evidência entre sessões como *atributos*, a saber a parcela do *cluster* que carrega o mesmo JA4 ou o mesmo /24

Tabela I
ROC AUC POR SESSÃO [IC 95%] NO CENÁRIO *simético* REALISTA DE PRODUÇÃO (*fingerprints* BENIGNOS EM ZIPP, $\alpha = 1,5$; *botnet* ESPALHADA POR 25 *stacks* TLS), $n = 30$ SEMENTES, *baseline* POR SESSÃO FORTE, USUÁRIOS LEGÍTIMOS NO *mesmo* SERVIÇO SOB ATAQUE.

Configuração	$K = 50$	$K = 1000$
(a) ML por sessão (forte)	0,498 [.47–.53]	0,503 [.50–.51]
(b) ontologia, sem <i>relatedBy</i>	0,500 [.47–.53]	0,502 [.49–.51]
(c) só <i>NetworkProximity</i>	0,499 [.46–.53]	0,659 [.65–.67]
(d) arcabouço completo	0,927 [.92–.93]	0,982 [.98–.98]
<i>(a) e (d) por família de modelo (estimativa pontual)</i>		
hist. gradient boosting	0,502 / 0,921	0,501 / 0,990
<i>perceptron</i> multicamadas	0,471 / 0,235 [†]	0,500 / 0,803
regressão logística	0,488 / 0,873	0,495 / 0,799
Fernandes et al. [14]	0,518	0,509
Bharathi e Sukanesh [15]	0,520	0,509
Kemp et al. [5]	0,499	0,503

[†] abaixo do acaso: o *perceptron* inverte, tendo aprendido que um *fingerprint* amplamente compartilhado indica tráfego benigno. Ver texto.

mais o tamanho do *cluster*, e não consultando o grafo RDF. É um *proxy* em nível de atributo da representação que a família *relatedBy* codifica, escolhido para que toda configuração difira apenas em representação, e não no dado subjacente ou no classificador. A ablação isola portanto a *representação*, e seu resultado é uma afirmação sobre representação: ela não evidencia, por si só, a camada simbólica. O que a ontologia e a formulação SPARQL/SWRL acrescentam é avaliado à parte, como a derivação auditável e o escopo de mitigação derivado.

Além das métricas padrão de classificação, reportamos o **dano colateral**: a fração de tráfego legítimo que cai dentro do escopo derivado do veredicto. As cadeias de evidência são avaliadas quanto a *completude* (enumeram toda sessão correlacionada e toda sub-relação ativada?) e *acionabilidade* (o escopo derivado é coerente com o discriminador do *cluster*?).

V. RESULTADOS

A. Ablação em Campanhas Furtivas Distribuídas

A Tabela I reporta a ROC AUC por sessão em campanhas furtivas distribuídas nas quais os usuários legítimos acessam o *mesmo endpoint* na mesma porta do ataque, de modo que nem o volume de fluxo nem a porta de destino separam as duas classes. O padrão é nítido e, o que é crucial, *resiste a um baseline forte*: a detecção por sessão (a) com o conjunto completo de atributos de fluxo, os três *baselines* acadêmicos, e a configuração (b), que acrescenta atributos ontológicos por sessão mas nenhuma relação entre sessões, ficam todos no acaso ($AUC \approx 0,50$), porque cada sessão atacante é, por construção, amostrada das distribuições benignas. O arcabouço completo (d) alcança 0,93–0,98. A configuração (c), restrita à proximidade de rede, é fraca (0,50–0,66) precisamente porque a *botnet* está dispersa.

A afirmação de que *nenhum* detector por sessão separa este regime não deveria repousar sobre uma única classe de hipótese, então repetimos a ablação com *histogram gradient boosting*, um *perceptron* multicamadas e regressão logística sobre os mesmos atributos e a mesma partição (Tabela I). A configuração (a) permanece no acaso em todas as famílias,

Tabela II

O CAMINHO SPARQL/ENRIQUECIMENTO AVALIADO PONTA A PONTA COMO DETECTOR, EM QUE AS SESSÕES QUE CASAM COM O ESCOPO DERIVADO *são* AS SESSÕES MARCADAS, SEM CLASSIFICADOR, SEM TREINO E SEM LIMIAR, CONTRA O MODELO APRENDIDO FORÇADO AO MESMO PONTO DE OPERAÇÃO — COM EXCEÇÃO DA LINHA ADVERSARIAL, DISCUTIDA NO TEXTO. $K = 1000$, $n = 15$ SEMENTES.

Cenário	regra simbólica			modelo aprendido (d)		
	recall	FPR	F_1	AUC	rec. @ FPR=0	
monolítica ($M=1$)	84,0%	0,00%	0,885	0,997	91,7%	
$M=5$	90,0%	0,00%	0,948	0,996	88,6%	
$M=25$	90,3%	0,00%	0,949	0,979	36,4%	
$M=100$	85,0%	0,00%	0,919	0,961	17,6%	
$M=25$, adversarial	30,4%	3,78%	0,452	0,862	7,8%	

entre 0,471 e 0,502, de modo que o colapso é propriedade da representação, e não do aprendiz; os três *baselines* acadêmicos reimplementados, que consomem o mesmo conjunto de atributos, ficam no mesmo lugar.

É na configuração (d) que a escolha do modelo começa a importar, e o cenário realista expõe por quê. Fragmentar a *botnet* em 25 *stacks* torna a evidência entre sessões *não-monotônica* no rótulo: um atacante compartilha seu *fingerprint* com algumas dezenas de pares, enquanto um cliente legítimo na cabeça da distribuição benigna o compartilha com centenas. Ensembles de árvores recortam a faixa intermediária e alcançam 0,98–0,99 em $K = 1000$ e 0,92–0,93 em $K = 50$; a regressão logística, restrita a resposta monotônica, cai para 0,80 e 0,87; e o *perceptron* inverte de vez em $K = 50$ (AUC = 0,235), tendo aprendido que um *fingerprint* amplamente compartilhado indica tráfego benigno. Os contrastes pareados sobre o aprendiz de referência permanecem decisivos ($p_{\text{Bonf}} = 7,5 \times 10^{-9}$; d de Cohen = +22,4 para (d)–(a) e +13,5 para (d)–(c) em $K = 1000$).

Essa não-monotonicidade argumenta a favor do caminho simbólico, e não contra a abordagem: um modelo aprendido precisa inferir a linha de base benigna a partir de sua amostra de treino e codificá-la numa fronteira, ao passo que a regra da Seção III-G compara contra um perfil explícito. É por isso que o enriquecimento se comporta de modo uniforme na mesma faixa de fragmentação em que os aprendizes divergem.

Que (b) também fique no acaso é o resultado isolado mais informativo: atributos ontológicos por sessão não bastam. É a *relação explícita* entre sessões que carrega a detecção.

A massa de $\Omega(S)$ que dispara a regra é dominada por *relatedByTLSPFingerprint* ($w = 1,0$) e pela convergência de *endpoint*; *relatedByNetworkProximity* não ativa em campanhas dispersas. Avaliamos também a qualidade das cadeias de evidência sobre sete *clusters* de ataque reais: todas as sete enumeram a regra satisfeita, as sub-relações ativadas com seus pesos, o escore $\Omega(S)$ e o escopo derivado, e todas produzem um filtro diretamente aplicável (Listagem 2, Apêndice D). Um estudo com analistas humanos fica como trabalho futuro.

B. A Própria Regra como Detector

Todos os números até aqui vieram de um classificador sobre atributos entre sessões, o que mede a representação e nada

Tabela III

DDoS SLOWLORIS NO CIC-IOT2023 (*dados reais*, 143 PREFIXOS /24 DISTINTOS). O *baseline* POR SESSÃO *forte* NÃO COLAPSA; O GANHO DO RACIOCÍNIO ENTRE SESSÕES SOBRE ELE É MARGINAL NESTE ATAQUE CONVENCIONAL.

Método	F_1	Prec.	Rec.	AUC
KLAGE, nível de nó [7]	0,841	—	—	—
(a) ML por sessão, 3 atrib.	0,179	0,691	0,103	0,551
(a') ML por sessão, 8 atrib.	0,900	0,901	0,899	0,987
(d) entre sessões (nosso)	0,911	0,908	0,915	0,982

diz sobre a camada simbólica. Avaliamos portanto a regra diretamente: as sessões que casam com o escopo derivado na Seção III-G *são* o conjunto marcado, sem treino e sem limiar, e a decisão chega acompanhada de sua derivação. Como a AUC é uma medida de ordenação e a regra emite decisão dura, forçamos também o classificador ao ponto de operação da própria regra (Tabela II).

O resultado não é uniforme, e sua forma é o ponto. Contra uma *botnet* monolítica ou pouco fragmentada, o modelo aprendido é competitivo a falso positivo zero (91,7% e 88,6% de *recall* contra 84,0% e 90,0%): não há vantagem simbólica no regime fácil. A partir de 25 *stacks* a ordem se inverte acentuadamente: 90,3% contra 36,4%, e 85,0% contra 17,6% em cem *stacks*, e a regra mantém a vantagem mesmo contra um modelo autorizado a gastar falsos positivos: a 1% de FPR ele chega a apenas 66,8% e 44,5%. A linha adversarial *não* é comparação equivalente e não afirmamos nada a partir dela — ali a própria regra vaza 3,78%, e o modelo chega a 23,4% quando lhe permitem 1%, de modo que a ordem num ponto de operação equiparado fica em aberto.

O que a coluna de AUC esconde é exatamente isto. O classificador ainda marca 0,979 e 0,961 onde recupera um terço e um sexto do ataque: sua ordenação é boa, mas seus escores se sobrepõem ao tráfego benigno na cauda, de modo que nenhum limiar produz ação automática sem colateral. A regra não produz escore para limiarizar; produz um conjunto definido por um teste de enriquecimento contra um fundo explícito, e é por isso que sua taxa de falso positivo é nula onde exista discriminador enriquecido — nula por construção e não por ajuste, mas não incondicionalmente.

C. Tráfego Real e Comparação com o KLAGE

A Tabela III contrasta fortemente com a Tabela I. Um *baseline* por sessão *magro* (três atributos) colapsa para $F_1 = 0,179$, mas um *forte* (oito atributos de fluxo) alcança $F_1 = 0,900$, porque o Slowloris real do CIC-IoT2023, ao contrário das nossas campanhas furtivas sintéticas, deixa assinatura de fluxo por sessão. O arcabouço entre sessões alcança $F_1 = 0,911$, à frente por apenas +0,011.

Três leituras honestas decorrem daí. Primeiro, *neste ataque real a coordenação entre sessões não é necessária*: um classificador por sessão competente o separa, porque o ataque nunca foi calibrado para mimetizar o fluxo benigno. Segundo, a comparação com o KLAGE é favorável mas *não controlada*: nosso 0,911 supera o 0,841 publicado, mas nosso próprio

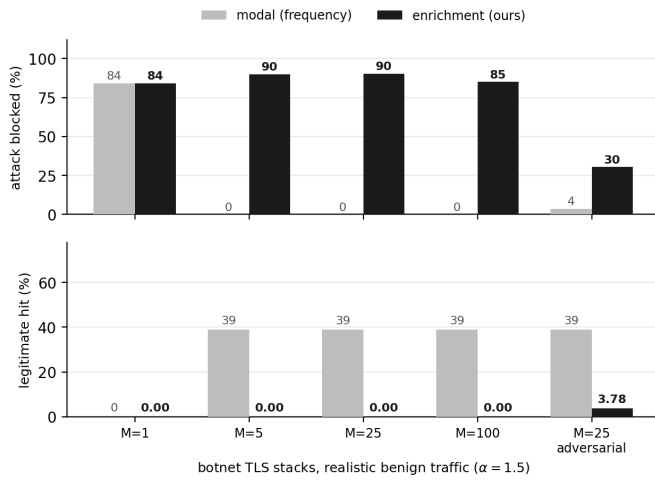


Fig. 3. Escolher o discriminador por frequência *versus* por enriquecimento, sob concentração realista de *fingerprints* benignos ($\alpha = 1,5$). A regra modal só se sustenta para *botnet* monolítica; a partir de cinco *stacks* ela não bloqueia atacante algum e atinge 39% dos usuários legítimos. O enriquecimento é invariante à fragmentação e, sob adoção adversarial de *fingerprint*, recusa em vez de causar dano. $n = 15$ sementes.

baseline forte também o supera com 0,900, de modo que a margem *não* é atribuível ao raciocínio entre sessões. O KLAGÉ também classifica nós de rede em tipos de ataque enquanto nós classificamos sessões de forma binária. Uma reexecução controlada não é possível no momento: o código publicado parte de um grafo já construído cuja construção a partir do conjunto bruto não é publicada, e não distribui pesos, de modo que qualquer reexecução repousaria sobre nossa própria reconstrução dele. Terceiro, a necessidade do raciocínio entre sessões aparece no regime furtivo distribuído, que os *datasets* públicos de DDoS, restritos a ataques com assinatura de fluxo evidente, simplesmente não contêm (Fig. 4, Apêndice C). O que a abordagem em nível de sessão acrescenta *incondicionalmente* sobre o estado da arte em nível de nó é o veredicto simbólico auditável e uma medida de dano colateral.

D. Dano Colateral em Tráfego Legítimo

A mitigação só é significativa como par: o que o escopo derivado bloqueia, e quanto custa. Reportamos ambos sobre $n = 15$ campanhas por configuração, comparando a regra por frequência contra a regra por enriquecimento da Seção III-G (Fig. 3).

Para uma *botnet* monolítica as duas concordam: 84,0% das sessões atacantes bloqueadas a 0,00% de colateral, contra 100% para um *rate-limit* global no *endpoint*, que por definição desconecta todo usuário legítimo do serviço atacado. Esse é o regime em que a regra por frequência foi validada, e ele não é representativo. A partir de cinco *stacks*, o *fingerprint* modal do *cluster* passa a ser um *legítimo* e a regra inverte: 0,0% do ataque bloqueado e 39,0% do tráfego legítimo atingido. Isso é pior do que não fazer nada, já que impõe o custo da mitigação e não entrega nenhum de seus benefícios. Uma população

benigna mais concentrada ($\alpha = 2,0$) eleva esse colateral para 61,1%.

O enriquecimento elimina a falha, bloqueando 90,0%, 90,3% e 85,0% do ataque em $M = 5, 25$ e 100 *stacks*, em todos os casos a 0,00% de colateral, e reproduzindo a regra por frequência onde esta funcionava. Os 10–15% que sobrevivem são a cauda de atacantes com *fingerprints* avulsos: a mitigação de escopo derivado troca completude por precisão.

Dois condições delimitam o resultado. A primeira é adversarial: quando a *botnet* adota *fingerprints* benignos comuns, pouco fica enriquecido e a regra bloqueia 30,4% do ataque a 3,78% de colateral, contra 3,6% e 39,0% da regra por frequência. A vantagem cirúrgica é em larga medida perdida, mas é perdida *com segurança*: com um ρ mais estrito o escopo recusa nomear um *fingerprint* e degenera para o controle global, que é o relato correto quando não existe discriminador. A segunda é o perfil de fundo. Um desvio moderado é tolerável (perfil com $\alpha = 2,0$ contra episódio com $\alpha = 1,5$: 90,3% de cobertura, 0,45% de colateral); um perfil plano ou ausente não é, pois então todo *fingerprint* parece raro, a cabeça benigna marca como enriquecida, e o colateral salta para 81,2%. A cobertura não é afetada em nenhum dos casos, já que a qualidade do perfil governa a precisão e não o *recall*, de modo que mantê-lo é requisito de implantação e não otimização.

E. Custo e a Escolha de W

O Apêndice D mede as duas camadas do *pipeline* em função da ocupação da janela. Dois resultados importam: a admissão custa constantes 14–20 ns por par candidato, sustentando cerca de 84 000 admissões de sessão por segundo em um núcleo com $|S_W| = 1 000$; e a detecção é plana numa faixa de $30 \times$ em W , enquanto a ocupação do *cluster*, e com ela o termo quadrático de pares que $\Omega(S)$ implica, cresce $6,6 \times$. Mantenha W tão pequeno quanto o tráfego permitir.

F. Significância Estatística

Aplicamos testes pareados de Wilcoxon sobre as $n = 30$ execuções, com correção de Bonferroni e d de Cohen. No regime distribuído ($K = 1000$), (d)–(c) é significativa com $p_{\text{Bonf}} = 7,5 \times 10^{-9}$ e $d = 13,5$, e (d)–(a) com $p_{\text{Bonf}} = 7,5 \times 10^{-9}$ e $d = 22,4$. Tamanhos de efeito dessa magnitude refletem a natureza controlada do tráfego sintético, que produz separação quase perfeita, e não devem ser lidos como expectativa de desempenho em campo.

VI. DISCUSSÃO E LIMITAÇÕES

Cinco limitações delimitam a afirmação, intercaladas abaixo com dois parágrafos que posicionam o arcabouço operacionalmente; outras estão no Apêndice C.

O ganho é específico de regime. Contra ataques de origem única e alto volume, limiares por IP ou por sessão têm desempenho comparável, e nos ataques reais convencionais disponíveis em *datasets* públicos um classificador por sessão forte já alcança $AUC \geq 0,98$, deixando ao raciocínio entre sessões apenas um ganho marginal. A vantagem é decisiva apenas quando a campanha é distribuída e furtiva. Este trabalho

não substitui defesas volumétricas; as complementa. Validar a abordagem sobre tráfego furtivo distribuído *capturado*, que nenhum *benchmark* público oferece, é a direção experimental mais importante.

A avaliação sintética demonstra um mecanismo, não desempenho em campo. No cenário sintético, os sinais de coordenação presentes na campanha são exatamente aqueles medidos pela configuração (d), e as sessões atacantes tomam seus atributos por sessão de distribuições benignas reais. A não-separabilidade por sessão da Tabela I não é, portanto, artefato de um *baseline* enfraquecido, já que quatro famílias de modelo com todos os atributos de fluxo permanecem no acaso. O mimetismo é imposto por construção, de modo que o resultado mostra o mecanismo sob a hipótese de indistinguibilidade por sessão perfeita, e não prova desempenho sobre uma captura real desse regime.

Deteção e derivação de escopo dependem ambas de um discriminador de peso alto observável. Uma varredura de robustez ($n = 10$) torna a dependência explícita: à medida que a fração de origens que compartilham o *fingerprint* TLS cai, a AUC(d) decresce monotonicamente de 1,00 para $\approx 0,74$ sob randomização total. Esse resíduo acima do acaso é artefato de um *pool* finito de JA4 benigno, de modo que sob diversidade em escala de internet ele deve tender ao acaso. A convergência de *endpoint* não compensa a perda do JA4 quando os usuários legítimos compartilham o *endpoint*, porque eles também convergem nele. Adversários podem forjar o JA4 com ferramentas como *curl-impersonate*, aplicar *jitter* à temporização e rotacionar identidades; a família ponderada tolera quebra parcial, já que os sinais de peso alto remanescentes carregam o *cluster*, mas quebrar três ou mais de uma vez a degrada em direção ao acaso. A adoção ampla do Encrypted Client Hello [22] poderia igualmente tornar o JA4 inobservável, exigindo metadados TLS alternativos para compensar.

Posicionamento operacional. O arcabouço fecha um laço de gestão em vez de emitir rótulos: deteção, evidência e escopo saem de uma passagem sobre o mesmo grafo, de modo que o que chega ao operador ou a um *playbook* de SOAR é um *course-of-action* STIX já parametrizado pelo discriminador que justificou o veredicto. A janela deslizante é o que torna isso viável (Seção V-E). É um complemento no plano de sessão às defesas volumétricas na borda, não um substituto.

Paralelismo e particionamento. A própria regra dita a chave natural de partição. A condição (ii) exige que toda sessão de S tenha o mesmo *endpoint* e como alvo, então particionar a janela ativa por *endpoint* avalia CoordinatedHTTPFlood *exatamente*, sem tráfego entre partições: o detector torna-se trivialmente paralelo sobre *endpoints*, e como a janela limita $|S_W|$, o estado por partição não cresce com o volume acumulado de tráfego. O custo não é zero, contudo. Particionar por *endpoint* esconde uma campanha que espalha um mesmo JA4 por muitos *endpoints*, já que nenhuma partição acumula pares coordenados suficientes para ultrapassar τ_{cluster} ; particionar por JA4 preserva exatamente essas campanhas e quebra a condição de *endpoint*.

Nenhuma chave isolada preserva as seis sub-relações, e isso é propriedade de $\Omega(S)$ e não de qualquer implementação. O desenho que isso sugere, não implementado, é em dois níveis: trabalhadores particionados por *endpoint* mais um *sketch* global sobre identificadores de peso alto para recuperar campanhas entre *endpoints*; quantificar o *recall* perdido pelo primeiro nível e recuperado pelo segundo é pré-requisito para implantação em escala de CDN. Tomadas em conjunto com a Seção V-E, essas observações compõem um único argumento de escalabilidade: o particionamento por *endpoint* é exato e dispensa coordenação, um W pequeno não custa deteção enquanto corta o termo quadrático de pares, e a admissão custa microssegundos. Numa implantação corretamente configurada, o termo quadrático portanto nunca morde.

A ablação mede representação, não formalismo. A configuração (d) alcança a evidência do grafo por atributos e não por SPARQL: um modelo linear sobre os mesmos três atributos entre sessões ainda alcança 0,799 contra 0,495 do conjunto por sessão, de modo que o ganho de AUC na Tabela I é atribuível a representar estrutura entre sessões, e não a expressá-la em OWL. A camada simbólica é evidenciada à parte, pela Tabela II, e apenas em parte: ela não supera o modelo aprendido contra *botnet* monolítica, e sua vantagem aparece quando a fragmentação ou a adoção adversarial de *fingerprint* tornam a distribuição de escores inutilizável para um limiar de falso positivo zero. As duas afirmações devem ser lidas separadamente.

Cobertura de família de ataque, protocolo e dataset. A ontologia e a avaliação cobrem a família Slow HTTP DoS sobre HTTP/1.1; ataques sobre HTTP/2 e outros protocolos de aplicação exigem sub-relações que não modelamos. A validação em dados reais abrange seis ataques (Slowloris, Slowhttptest, HULK, GoldenEye, HTTP-Flood, DoS-Other) em dois *datasets*, mas todos são capturas de *testbed* de laboratório, e a comparação direta com o KLAGÉ é necessariamente de ataque único, já que é isso que o KLAGÉ publica. Essa comparação difere também em granularidade e protocolo, de modo que reproduzir o KLAGÉ sob nosso protocolo é necessário antes de qualquer afirmação de superioridade.

VII. CONCLUSÃO

Modelamos a sessão HTTP como entidade ontológica de primeira classe e substituímos a relação plana entre sessões por seis sub-propriedades tipadas, ponderadas pelo custo que o atacante teria para quebrar cada sinal. Uma regra SPARQL/SWRL dispara sobre a massa ponderada dessas sub-relações, de modo que uma única derivação serve ao mesmo tempo como veredicto, cadeia de evidência e escopo da mitigação.

Contra campanhas furtivas distribuídas, a deteção por sessão fica no acaso em quatro famílias de modelo, mesmo com o conjunto completo de atributos de fluxo, enquanto o arcabouço detecta de forma consistente (0,50 vs. 0,98 de ROC AUC; $d = 22,4$); em ataques reais convencionais o ganho é marginal, porque um classificador por sessão forte já basta. Do lado da mitigação, o estudo produziu um resultado

negativo que vale tanto quanto o positivo: derivar o escopo pela propriedade que a maioria do *cluster* compartilha seleciona um *fingerprint* legítimo assim que a *botnet* abrange mais de um *stack* TLS, bloqueando usuários em vez de atacantes. O enriquecimento sobre um perfil de tráfego normal restaura 85–90% de cobertura a 0,00% de colateral. E, medido como detector, esse caminho simbólico recupera 90% de uma campanha de 25 *stacks* onde o modelo aprendido recupera 36% no mesmo ponto de operação de falso positivo zero. Essa lacuna é escondida pela AUC, e é a evidência mais clara de que o grafo se paga. Direções imediatas são os ataques sobre HTTP/2 e uma campanha furtiva capturada, que nenhum *benchmark* ainda oferece.

AGRADECIMENTO

Agradecemos à Azion Technologies por autorizar a medição agregada de *fingerprints* reportada na Seção IV.

REFERÊNCIAS

- [1] MITRE Corporation, “CVE-2023-44487: HTTP/2 rapid reset attack,” National Vulnerability Database, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>
- [2] Google Cloud, “How it works: The novel HTTP/2 ‘Rapid Reset’ DDoS attack,” Google Cloud Blog, 2023. [Online]. Available: <https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack>
- [3] Cloudflare, “Hyper-volumetric DDoS attacks skyrocket: Cloudflare’s 2025 Q2 DDoS threat report,” Cloudflare Blog, 2025. [Online]. Available: <https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/>
- [4] E. Cambiaso, G. Papaleo, G. Chiola, and M. Aiello, “Slow DoS attacks: Definition and categorisation,” *International Journal of Trust Management in Computing and Communications*, vol. 1, no. 3–4, pp. 300–319, 2013.
- [5] C. Kemp, C. Calvert, T. M. Khoshgoftaar, and J. L. Leevy, “An approach to application-layer DoS detection,” *Journal of Big Data*, vol. 10, no. 1, p. 22, 2023.
- [6] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, and L. Fernández-Sanz, “A survey and meta-analysis of application-layer distributed denial-of-service attack,” *International Journal of Communication Systems*, vol. 33, no. 18, p. e4603, 2020.
- [7] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, and F. Marozzo, “Enhancing network security using knowledge graphs and large language models for explainable threat detection,” *Future Generation Computer Systems*, vol. 176, p. 108160, 2026.
- [8] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, “A practical approach to constructing a knowledge graph for cybersecurity,” *Engineering*, vol. 4, no. 1, pp. 53–60, 2018.
- [9] V. Bonagiri, P. Priyadharshini, P. PanneerSelvi, S. Sahitya, R. Swamy, and P. Varalakshmi, “Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions,” in *Proc. 4th Asian Conf. on Innovation in Technology (ASIANCON)*, 2024.
- [10] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, “Recent progress of using knowledge graph for cybersecurity,” *Electronics*, vol. 11, no. 15, p. 2287, 2022.
- [11] L. Sadlek, M. Husák, and P. Čeleda, “Identification of device dependencies using link prediction,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–10.
- [12] X. Wang and R. Stadler, “IT intrusion detection using statistical learning and testbed measurements,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–7.
- [13] N. Tripathi and N. Hubballi, “Application layer denial-of-service attacks and defense mechanisms: A survey,” *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–33, 2021.
- [14] G. Fernandes Jr., J. J. P. C. Rodrigues, and M. L. Proença Jr., “Autonomous profile-based anomaly detection system using principal component analysis and flow analysis,” *Applied Soft Computing*, vol. 34, pp. 513–525, 2015.
- [15] R. Bharathi and R. Sukanesh, “A PCA based framework for detection of application layer DDoS attacks,” *WSEAS Transactions on Information Science and Applications*, vol. 9, no. 12, pp. 389–398, 2012.
- [16] J. Althouse, J. Smart, R. J. Nunnally, and M. Brady, “JA4+ network fingerprinting,” FoxIO, 2023. [Online]. Available: <https://blog.foxio.io/ja4+-network-fingerprinting>
- [17] OASIS, “STIX version 2.1,” OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [18] W3C OWL Working Group, “OWL 2 web ontology language profiles, 2nd ed.” W3C Recommendation, 2012. [Online]. Available: <https://www.w3.org/TR/owl2-profiles/>
- [19] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proc. 4th Int. Conf. on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [20] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, “Understanding the Mirai botnet,” in *Proc. 26th USENIX Security Symposium*, 2017, pp. 1093–1110.
- [21] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, “CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment,” *Sensors*, vol. 23, no. 13, p. 5941, 2023.
- [22] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, “TLS encrypted client hello,” IETF Internet-Draft draft-ietf-tls-esni, 2024. [Online]. Available: <https://datatracker.ietf.org/doc/draft-ietf-tls-esni/>

APÊNDICE A

INSTANCIACÃO DAS SUB-RELAÇÕES RELATEDBY

Para cada par (s_a, s_b) ativo em W , os procedimentos a seguir decidem se a aresta é instanciada.

TLSFingerprint. Casamento em duas etapas: igualdade exata do JA4 completo ou, na falta dela, variantes próximas (mesmo prefixo de transporte/versão TLS/ALPN, com no máximo um símbolo de diferença nos blocos ordenados de *cipher* ou de extensões), instanciada com anotação $ja4_distance = 1$. Isso absorve a variação entre versões de uma mesma biblioteca cliente sem admitir casamentos espúrios entre *stacks* distintos. Custo $O(1)$ por par.

ReusedIdentity. Instanciada em qualquer sobreposição não-vazia entre os conjuntos de identidades observadas, $(cookie(s_a) \cap cookie(s_b)) \cup (token(s_a) \cap token(s_b)) \cup (user(s_a) \cap user(s_b)) \neq \emptyset$. JWTs são decodificados e comparados pelo *claim* sub; *cookies* e *usernames* são normalizados (*trim*, caixa baixa). Custo $O(1)$ amortizado com índice invertido.

TemporalPattern. Com $\Delta(s)$ a sequência de intervalos entre chegadas, computamos $d_{DTW}(s_a, s_b) = DTW(\Delta(s_a), \Delta(s_b)) / \max(|\Delta(s_a)|, |\Delta(s_b)|)$ e instanciamos quando $d_{DTW} \leq \tau_{DTW}$. Sessões com menos de três requisições são puladas. O FastDTW sob banda de Sakoe–Chiba de largura constante reduz o custo por par de $O(n^2)$ para $O(n)$, e *locality-sensitive hashing* sobre vetores de resumo ($\bar{\delta}$, σ_δ , $\delta_{\min}$, $\delta_{\max}$, entropia) evita a comparação de todos os pares.

PayloadSignature. Com $\mathbf{p}(s) = (\overline{len}, \sigma_{len}, h_{UA}, h_{CT})$, isto é, média e desvio-padrão do tamanho do corpo mais *hashes* do User-Agent e do Content-Type predominantes, a aresta é instanciada quando a similaridade de cosseno excede $\tau_{payload}$. Custo $O(1)$ dados os vetores pré-computados.

EndpointConvergence. Instanciada quando ambas as sessões convergem no mesmo *endpoint*, sob normalização de padrão de caminho (`/api/users/12345` →

```
# SWRL (Horn): instancia uma sub-relacao
ApplicationSession(?a) ^ ApplicationSession(?b) ^
differentFrom(?a,?b) ^
tlsJa4(?a,?j) ^ tlsJa4(?b,?j)
-> relatedByTLSFingerprint(?a,?b)

# SPARQL: agregacao ponderada sobre o cluster
SELECT ?e (SUM(?w) AS ?omega) (COUNT(*) AS ?pairs)
WHERE { ?a kg:targets ?e . ?b kg:targets ?e .
?rel ?a ?b .
?rel rdfs:subPropertyOf kg:relatedTo ;
kg:coordinationWeight ?w .
FILTER(STR(?a) < STR(?b)) }
GROUP BY ?e HAVING (SUM(?w) >= ?tau)
```

Listagem 1. Veredicto como derivação: regras de Horn materializam as arestas tipadas entre sessões; uma agregação SPARQL aplica os pesos declarados na ontologia e dispara a regra. Os *bindings* que satisfazem a consulta são a cadeia de evidência.

/api/users/{id}) por padrão; um casamento adicional de caminho exato anota a aresta com *exact = true*. Custo $O(1)$ com índice em árvore de prefixos.

NetworkProximity. Instanciada num prefixo IPv4 /24 (ou IPv6 /48) compartilhado, ou num ASN compartilhado, ou em ambos; quando ambos valem, a aresta é anotada com *strong = true*. A resolução de ASN usa tabelas BGP atuais. Custo $O(1)$ com índice invertido de prefixo.

APÊNDICE B CALIBRAÇÃO DOS PESOS

A calibração empírica depende criticamente do realismo do tráfego. Em *datasets* de laboratório, com poucas dezenas de *fingerprints* JA4 distintos, a otimização chega a inverter o sinal do TLS, porque as sessões benignas compartilham *fingerprints* mais do que as campanhas parcialmente coordenadas; isso é artefato de *testbed* pela baixa diversidade de JA4, ausente na internet real.

No cenário realista (milhares de *fingerprints* JA4 legítimos, com usuários acessando o serviço atacado), calibramos maximizando a ROC AUC por sessão de ataque vs. benigno sobre o escore $w_{\text{tls}} z(\text{ja4}) + w_{\text{ep}} z(\text{conv. endpoint}) + w_{\text{net}} z(\text{prox. rede})$ com atributos padronizados, sobre o *grid* $\{0,3 \dots 1,0\}^3$ (125 combinações, 60 cenários, 91 500 sessões). O resultado corrobora a ordenação proposta: o melhor vetor é $(w_{\text{tls}}=1,0, w_{\text{ep}}=0,3, w_{\text{net}}=0,3)$, e o *fingerprint* TLS é o único sinal individualmente discriminativo (AUC isolada = 0,93, contra 0,50 da convergência de *endpoint* e 0,58 da proximidade de rede). Os pesos da Fig. 1 (1,0, 0,6, 0,3) atingem a mesma AUC ótima = 0,943 e são insensíveis a perturbação de $\pm 20\%$ (sem queda mensurável). A calibração valida portanto a *ordenação*; no regime puro de mesmo serviço, os pesos médio e baixo não são separadamente identificáveis, já que isoladamente ambos ficam perto do acaso, e seus valores absolutos permanecem em aberto até que haja tráfego de produção com sinais parciais e conflitantes.

APÊNDICE C LIMITAÇÕES ADICIONAIS

Instrumentação de sessão e identidade. A abordagem assume que sessões, identidades e *fingerprints* TLS podem ser

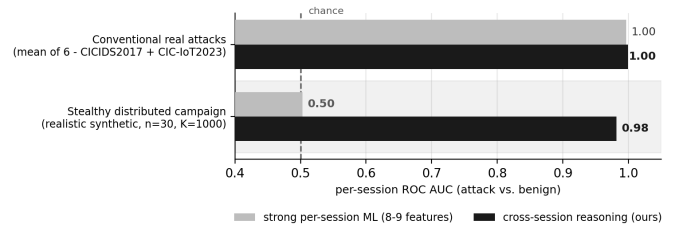


Fig. 4. Onde o raciocínio entre sessões é *necessário*. Em ataques reais convencionais um classificador por sessão forte já satura; só no regime furtivo distribuído a detecção por sessão colapsa para o acaso enquanto o raciocínio entre sessões se sustenta.

extraídos dos eventos de tráfego; onde essa instrumentação for parcial ou ruidosa, o desempenho degrada.

Custo de manutenção do grafo. Os números da camada simbólica do Apêndice D são um limite superior, pela razão dada lá; e escalar para tráfego em escala de CDN requer o particionamento horizontal da Seção VI, que não implementamos.

Cobertura de protocolo. A ontologia atual cobre a família Slow HTTP DoS sobre HTTP/1.1. Ataques sobre HTTP/2 e outros protocolos de aplicação (DNS, gRPC) exigem sub-relações adicionais.

Cobertura de sub-relações. O $\Omega(S)$ avaliado instancia três das seis sub-relações — *fingerprint* TLS, convergência de *endpoint*, proximidade de rede —, as que o gerador e as capturas públicas expõem. Reaproveitamento de identidade, padrão temporal e assinatura de *payload* estão no Apêndice A mas não são exercitados, então os pesos da Fig. 1 só estão validados para essas três.

Amplitude de datasets. A validação em dados reais cobre um *dataset* e um ataque para a comparação direta, mais seis ataques entre CICIDS2017 e CIC-IoT2023 para a análise de regime. RT-IoT2022, CIC-DDoS2019 e tráfego de produção anonimizado ficam como trabalho futuro.

Validação da explicação. As cadeias de evidência foram avaliadas quanto a completude estrutural e acionabilidade (7/7), mas a acionabilidade *percebida* — um estudo com analistas medindo tempo até a decisão e compreensão — não foi conduzida.

APÊNDICE D MODELO DE CUSTO E SENSIBILIDADE À JANELA

As duas camadas operam em taxas diferentes, já que a admissão acontece por requisição e a materialização simbólica com a agregação de Ω acontece por janela, então as medidas separadamente, sobre uma janela sintética na mistura realista de mesmo serviço (30% das sessões numa campanha compartilhando um JA4 de *botnet*, JA4 benigno de um *pool* de 2000, oito *endpoints*, /24s dispersos); medianas sobre três repetições em um núcleo. Este é um modelo de custo do algoritmo como especificado, e não um *benchmark* de sistema: o caminho de admissão implementa o esquema de índices invertidos da Seção III-D, e a camada simbólica roda sobre *rdflib* em memória, e não sobre o *backend* Jena/TDB2 usado no *pipeline* de *datasets*, de modo que seus números são um limite superior.

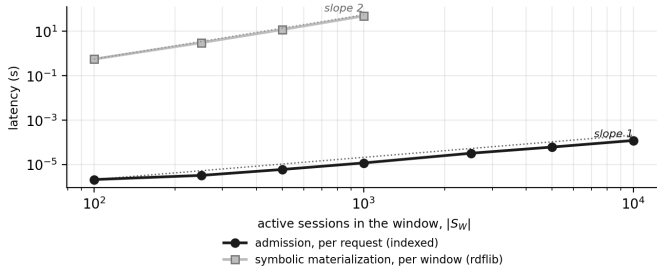


Fig. 5. Custo das duas camadas em função da ocupação da janela. A admissão por requisição é linear em $|S_W|$ e permanece na faixa de microssegundos; a materialização simbólica por janela é linear no número de arestas RDF, que por sua vez é quadrático em $|S_W|$. Retas de referência ancoradas no primeiro ponto de cada série.

Tabela IV

VARREDURA DA JANELA, $K = 1000$, $n = 10$ SEMENTES. A DETECÇÃO É PLANA NUMA FAIXA DE $30 \times \text{em } W$, ENQUANTO A OCUPAÇÃO DO *cluster*, E PORTANTO O TERMO QUADRÁTICO DE PARES, CRESCE COM ELA.

W (s)	clusters	$ S $ médio	(a)	(b)	(c)	(d)
60	16	132	0,505	0,508	0,664	0,976
120	11	207	0,505	0,508	0,663	0,977
300	6	364	0,505	0,508	0,664	0,977
600	4	557	0,505	0,508	0,664	0,978
1800	3	867	0,505	0,508	0,664	0,978

A admissão se comporta como o limite prevê (Fig. 5): a latência mediana cresce de $2,1 \mu\text{s}$ em $|S_W| = 100$ para $122 \mu\text{s}$ em $|S_W| = 10000$, acompanhando a contagem de pares candidatos (148 a 6495 arestas por admissão) a constantes 14–20 ns por par.

A camada simbólica é ordens de magnitude mais cara: $0,56 \text{ s}$ em $|S_W| = 100$, subindo para $49,7 \text{ s}$ em $|S_W| = 1000$. Lida por unidade de trabalho, contudo, o custo permanece entre 180 e $210 \mu\text{s}$ por aresta RDF materializada em todos os tamanhos, de modo que a camada é *linear em arestas*; é a contagem de arestas que cresce quadraticamente, porque $\Omega(S)$ é definida sobre pares. O termo quadrático é portanto propriedade da regra, e não do *backend*, e aponta para a divisão de implantação que a arquitetura já sugere: detectar pelo caminho indexado de admissão, e materializar RDF apenas para os *clusters* que disparam, isto é, o subconjunto da cadeia de evidência e não a janela inteira.

W entra apenas na atribuição de *clusters* de detecção, então a varredura recomputa os atributos entre sessões sobre os mesmos cenários em cache. A Tabela IV mostra que a detecção é insensível a ele entre 60 e 1800 s: o atributo discriminativo é a *fração* de um *cluster* que compartilha um mesmo JA4, que não muda conforme o *cluster* cresce, ao passo que o tamanho sozinho carrega pouco — daí (c) em 0,664 o tempo todo. Dois limites: os cenários têm um único *endpoint* alvo, então W é o único botão de agrupamento e uma implantação multi-*endpoint* pode se comportar de outra forma; e W precisa ser longo o bastante para um *cluster* se formar, o que em $W = 60 \text{ s}$ já significa ≈ 132 sessões.

```
"@type": "kg:CoordinatedHTTFFlood",
"kg:clusterSize": 6, "kg:coordinationScore": 10.8,
"kg:activatedSubRelations": [
{"@type": "kg:relatedByEndpointConvergence",
"kg:coordinationWeight": 0.6, "kg:linkedPairs": 15,
"kg:weightedContribution": 9.0},
{"@type": "kg:relatedByNetworkProximity",
"kg:coordinationWeight": 0.3, "kg:linkedPairs": 6,
"kg:weightedContribution": 1.8}],
"kg:derivedMitigationScope": {
"kg:endpoint": "192.168.10.50:80",
"kg:srcNet24": "172.16.0.0/24"}
```

Listagem 2. Cadeia de evidência emitida para o *cluster* DoS-Other do CICIDS2017 (JSON-LD, abreviada). Cada termo de $\Omega(S) = 10,8$ é atribuível a uma sub-relação, uma contagem de pares e um peso, e o último campo é o filtro efetivamente aplicado. A exportação STIX 2.1 carrega o mesmo conteúdo como padrão de *indicator* mais um *course-of-action* ligado por *mitigates*.

APÊNDICE E REPRODUTIBILIDADE

A implementação de referência está disponível em <https://github.com/NatanaelOliveira/knowledge-graph-ddos-article> sob licença permissiva, organizada por etapa experimental: o *pipeline* de extração (PCAP $\rightarrow$ JA4 e fluxos $\rightarrow$ sessões $\rightarrow$ grafo); o gerador sintético calibrado, com os três parâmetros de realismo da Seção IV e as configurações de cenário canônico e adversarial; a ablação, os *baselines* acadêmicos e as quatro famílias de modelo; o executor estatístico; a comparação contra o estado da arte publicado; a camada simbólica (regras SWRL mais a agregação SPARQL, com pesos lidos da ontologia); e os módulos de evidência e mitigação.

As duas derivações de escopo são distribuídas lado a lado: a regra por frequência que falha e a regra por enriquecimento que a substitui, de modo que o resultado negativo da Seção V-D seja reproduzível, e não apenas afirmado. O perfil de fundo de que o teste de enriquecimento precisa é produzido por uma execução do gerador sem ataque, então nenhum rótulo entra no caminho de decisão em momento algum. O modelo de custo do Apêndice D não requer *dataset* algum e roda em qualquer lugar.

As sementes são fixas, a orquestração é feita por Makefiles, e os artefatos, isto é figuras, distribuições calibradas e resultados agregados, são versionados; cada tabela e cada figura de dados deste artigo é regenerada por um único comando por etapa. A Fig. 1 é um esquema desenhado à mão, cuja fonte editável acompanha o artefato. A ontologia OWL é fornecida em RDF/XML, com cada sub-propriedade *relatedBy* anotada com seu *coordinationWeight*. Pretendemos submeter esses artefatos à trilha de Artifact Evaluation.